

Attack where malicious website tricks your browser into sending a request to another website where you are already logged in.

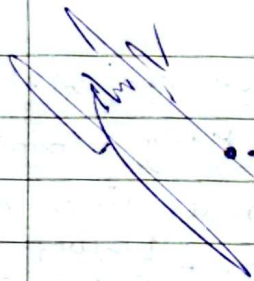
Cross-Site Request Forgery (CSRF)

Date: _____

XSRF

- Targets:- User who is already logged in
- Attacker :- make user's browser send request to that website.
- To server it looks like user sent request.
- Attacker just needs user to click a link.
- The browser automatically sends users login cookies.

Referer → send referer header where request came from. but referer is optional.



CSRF → website adds a secret token to every form
secret token → hidden/Random
= hard to guess

- CSRF → Double Submit Cookie.

defense

- Website creates a secret number
- Sends this number twice → once as a cookies + once inside form
- When submit form, website checks both numbers if they match.

- Same Site Cookies.

- ↓
- cookies is only sent when you stay on same site.
- If another site triggers request - cookie not sent.

Types → (1) Strict (cookies sent only for same site)

(2) lax (cookies sent when we click links)

more good.